THE MARRIOTT INTERNATIONAL DATA BREACH: GDPR INVESTIGATION AND REGULATORY FINE

A CASE STUDY REPORT

submitted by:

DON JOE BIJU (VML24AD055)

to

The APJ Abdul Kalam Technological University

in partial fulfillment of the requirements for the degree of

Bachelor of Technology

In

Artificial Intelligence and Data Science

DEPARTMENT OF COMPUTER SCIENCE AND ENGINEERING

ARTIFICIAL INTELLIGENCE AND DATASCIENCE

VIMAL JYOTHI ENGINEERING COLLEGE CHEMPERI

CHEMPERI P.O.- 670632, KANNUR, KERALA, INDIA

INDEX

SI.NO.	CONTENTS	PAGE NO.
1	INTRODUCTION	3
2	BACKGROUND OF THE ORGANIZATION / CASE	3
3	PROBLEM OR VIOLATION DESCRIPTION	4
4	ANALYSIS (LAWS / PRINCIPLES VIOLATED)	4
5	IMPACT / CONSEQUENCES	5
6	ACTIONS TAKEN OR PENALTIES	6
7	PREVENTIVE MEASURES	6
8	CONCLUSION	7
9	REFERENCES	7

1. INTRODUCTION

In the digital era, organizations collect and store large volumes of customer data in order to provide personalized services and improve business operations. Industries such as hospitality, banking, and e-commerce rely heavily on digital systems and databases to manage customer reservations, payments, and personal information. While these technologies improve efficiency, they also increase the risk of cyber attacks and data breaches. One of the most significant data breaches in the hospitality industry involved **Marriott International**, one of the largest hotel chains in the world. The company manages thousands of hotels across multiple countries and stores large amounts of guest information in its reservation systems.

In 2018, Marriott disclosed a massive cyber security breach affecting its **Starwood guest reservation database**. Attackers had gained unauthorized access to the system and were able to extract sensitive customer information over a long period of time. The breach exposed personal data of hundreds of millions of guests worldwide. The incident raised serious concerns about data security, privacy protection, and regulatory compliance. Because the breach involved personal data of individuals from the European Union, it was investigated under the **General Data Protection Regulation (GDPR)**, one of the strictest data protection laws in the world.

This case study examines the Marriott International data breach, focusing on the causes of the incident, the regulatory investigation, and the penalties imposed. It also analyzes the impact of the breach and discusses preventive measures organizations should adopt to protect customer data.

2. BACKGROUND OF THE ORGANIZATION / CASE

Marriott International is a multinational hospitality company founded in 1927 and headquartered in the United States. The company operates thousands of hotels and resorts across more than 130 countries and serves millions of customers each year.

In 2016, Marriott acquired **Starwood Hotels & Resorts Worldwide**, another major hotel group. The acquisition significantly expanded Marriott's global presence but also introduced complex technology systems and large customer databases into the company's infrastructure. The breach involved the Starwood guest reservation system, which stored information related to hotel bookings and customer profiles. According to investigations, unauthorized access to this system began in 2014, before the acquisition by Marriott. However, the breach remained undetected for several years. In 2018, Marriott discovered suspicious activity in the Starwood database and launched an internal investigation. The investigation revealed that attackers had been able to access and extract large amounts of sensitive data from the system.

The exposed data included guest names, mailing addresses, phone numbers, email addresses, passport numbers, dates of birth, and reservation details. In some cases, encrypted payment card information was also compromised. The breach affected approximately **500 million guest records**, making it one of the largest data breaches in the hospitality industry. Because the incident involved personal data belonging to European Union residents, regulatory authorities

launched an investigation under GDPR to determine whether Marriott had taken sufficient measures to protect customer data.

3. PROBLEM OR VIOLATION DESCRIPTION

The primary problem in the Marriott case involved unauthorized access to the Starwood reservation database, which allowed attackers to extract sensitive personal information from millions of customer records. One of the most serious concerns was the **long duration of the breach**. Attackers had access to the system for several years before the incident was discovered. This suggests weaknesses in the company's monitoring and cyber security detection systems. Another major issue involved the **storage of highly sensitive personal data**. The compromised database contained detailed customer information such as passport numbers, contact details, and reservation histories. Exposure of such information can lead to identity theft, fraud, and privacy violations. The breach also raised questions regarding **data security practices during corporate acquisitions**. When Marriott acquired Starwood Hotels, it inherited the company's existing technology systems and databases. However, it appears that vulnerabilities in the Starwood system were not fully identified or addressed before integration. Another concern involved the **lack of effective risk assessment and cyber security controls**. The attackers were able to maintain unauthorized access for an extended period without being detected. The case therefore highlighted serious challenges in cyber security management, data protection practices, and corporate responsibility for protecting customer information.

4. ANALYSIS (LAWS / PRINCIPLES VIOLATED)

The Marriott breach can be analyzed based on key data protection principles established by the General Data Protection Regulation (GDPR).

- ### Principle of Integrity and Confidentiality

This principle requires organizations to ensure that personal data is protected against unauthorized access, loss, or misuse. The Marriott breach demonstrated failures in protecting the confidentiality of customer data stored in the Starwood database.

- ### Accountability Principle

Organizations are responsible for ensuring compliance with data protection regulations and must demonstrate that appropriate security measures are in place. Regulators found that Marriott had not implemented sufficient safeguards to detect and prevent unauthorized access.

- ### Data Protection by Design and by Default

GDPR requires organizations to integrate security and privacy protections into their systems from the beginning. Weaknesses in the Starwood reservation system indicated that adequate protections were not implemented.

- **Risk Management and Security Monitoring**

Organizations must regularly assess cyber security risks and monitor systems for suspicious activity. The long period during which attackers remained undetected suggests weaknesses in Marriott's monitoring systems.

- **Protection of Sensitive Personal Data**

The database contained highly sensitive information such as passport numbers. Such data requires strong protection mechanisms because misuse could lead to serious privacy and security risks.

5. IMPACT / CONSEQUENCES

The Marriott data breach had significant consequences for customers, the organization, and the global hospitality industry.

- **Impact on Customers**

Millions of customers had their personal information exposed, increasing the risk of identity theft, fraud, and phishing attacks. Exposure of passport numbers and contact details created serious privacy concerns.

- **Financial Impact on the Organization**

Data breaches can lead to major financial losses due to regulatory penalties, legal costs, and cyber security improvements.

- **Reputational Damage**

Public trust in the company was affected as customers questioned the organization's ability to protect their personal information.

- **Regulatory Investigation**

European data protection authorities launched a formal investigation into the breach under GDPR regulations.

- **Industry Awareness**

The incident increased awareness across the hospitality industry about the importance of protecting customer data and implementing strong cyber security systems.

6. ACTIONS TAKEN OR PENALTIES

Following the discovery of the breach, Marriott International took several actions to address the incident and strengthen its cyber security practices. The company notified affected customers and advised them to monitor their accounts for suspicious activity. Marriott also provided guidance on protecting personal information and preventing identity theft.

The breach was investigated by the UK Information Commissioner's Office (ICO), the data protection authority responsible for enforcing GDPR in the United Kingdom. After reviewing the case, the ICO concluded that Marriott had failed to implement appropriate security measures to protect customer data. As a result, the company was fined approximately **£18.4 million** under GDPR regulations. The company also invested heavily in improving its cyber security infrastructure, including better monitoring systems, stronger encryption techniques, and improved data protection policies.

7. PREVENTIVE MEASURES

Organizations that store large volumes of customer data should adopt several preventive measures to reduce the risk of similar breaches.

- **Strong Cyber security Infrastructure**

Organizations should implement advanced security technologies such as intrusion detection systems, encryption, and secure authentication mechanisms.

- **Regular Security Audits**

Frequent security assessments and penetration testing can help identify vulnerabilities in systems before attackers exploit them.

- **Secure Integration During Mergers and Acquisitions**

Companies acquiring other organizations must carefully review the cyber security practices of the acquired systems.

- **Data Encryption**

Sensitive customer data should be encrypted both during storage and transmission.

- **Continuous Monitoring**

Real-time monitoring systems should be used to detect suspicious activities and unauthorized access attempts.

- **Employee Cyber security Training**

Employees should be trained to recognize potential security threats and follow safe data management practices.

8. CONCLUSION

The Marriott International data breach is one of the most significant cyber security incidents in the hospitality industry. The breach exposed the personal information of hundreds of millions of customers and revealed serious weaknesses in data protection and cyber security management. The incident demonstrates the importance of implementing strong security systems, conducting regular risk assessments, and ensuring compliance with data protection regulations such as GDPR.

Organizations that manage large customer databases must prioritize privacy protection and ethical data management practices. Protecting personal information is not only a legal obligation but also a critical factor in maintaining customer trust. The case also highlights the importance of proactive cyber security strategies, especially during corporate mergers and acquisitions. By integrating strong security measures, continuous monitoring, and responsible data governance, organizations can reduce the risk of large-scale data breaches and ensure safer digital environments.

9. REFERENCES

- European Union. (2016). General Data Protection Regulation (GDPR).
- UK Information Commissioner's Office. (2020). Marriott International Data Breach Investigation Report.
- BBC News. (2020). Marriott Fined for Massive Data Breach.
- Reuters. (2019). Marriott Data Breach Exposes Millions of Guests.
- Cyber security & Infrastructure Security Agency. (2020). Data Protection and Cyber security Guidelines